

Plataforma Educativa

CMS educativo interactivo para infantil y primaria

Manual Tecnico y de Usuario - V-0.10.1

Este documento describe la arquitectura, endpoints de la API, modelo de datos, guía de instalación y manual de uso de la Plataforma Educativa V-0.10.1. Esta versión añade ROBUSTEZ: copias de seguridad automáticas de la base de datos (copia en caliente del SQLite + rotación) y purga programada de la papelera (borrado definitivo del contenido que lleva más de 30 días borrado), con un nuevo panel de administración para gestionar las copias.

Fecha: 2026-06-16

Version del software: V-0.10.1

Licencia: MIT (open source)

NOVEDADES DE V-0.10.1

0. Cambios de esta version

Seguridad de las imagenes Docker

- Backend: base python:3.12-slim -> python:3.12-slim-bookworm (release de Debian explicita) y parches de seguridad del SO en el build (apt-get upgrade), que aplican las correcciones de Debian posteriores a la imagen base (el grueso de los hallazgos del escaner).
- Se actualizan pip/setuptools/wheel (sus versiones antiguas son un hallazgo recurrente).
- Frontend: etapa final nginx:alpine con apk upgrade (paridad de parches del SO).
- Nueva guia docs/seguridad-imagenes.md: como escanear las imagenes ya construidas (Trivy, --ignore-unfixed), fijar la base por digest y endurecimiento pendiente (usuario no-root).

Notas

- El escaner del IDE marca el tag base ANTES del apt-get upgrade; tras el build, las CVEs con parche quedan resueltas y las restantes suelen ser 'sin fix' en Debian.
- Sin cambios de codigo, API ni esquema: 123 tests siguen en verde.
- Al desplegar no hace falta nada especial; el endurecimiento se aplica al reconstruir.

PARTE I - MANUAL TECNICO

1. Descripcion del sistema

Plataforma web educativa tipo CMS para alojar y ejecutar ejercicios interactivos (HTML/CSS/JS autocontenidos) y articulos de texto, dirigidos a alumnado de infantil y primaria en Espana. Acceso publico sin cuentas de alumno. Dos roles privilegiados: admin (configuracion + contenidos) y editor (gestion de contenidos).

Caracteristicas principales

- Contexto configuration: paletas de color configurables desde el panel admin.
- Frontend React MVP completo: catalogo, login, panel admin con todas las secciones.
- CRUD de taxonomias (ciclos, cursos, asignaturas) con edicion inline en el frontend.
- Script seed_admin y endpoint Docker con auto-creacion del admin inicial.
- Sistema de diseno CSS con variables custom (--cms-color-*) y clases prefijadas cms-.
- Paletas predefinidas infantiles aplicables en tiempo real sin recargar la pagina.
- Paletas personalizadas con color pickers y preview en vivo.
- Ajustes generales: nombre del sitio editable y seleccion de fuente de letra.
- Fuentes self-hosted (Nunito, Quicksand, Lexend, Atkinson Hyperlegible, Andika).
- Creacion/edicion de articulos de texto con editor WYSIWYG (Tiptap) y HTML saneado.
- Fondos/estampados tematicos (Aula, Naturaleza, Espacio, Oceano, Geometrico, Granja).

2. Arquitectura del backend

Stack tecnologico

Lenguaje	Python 3.12+
Framework API	FastAPI
ORM	SQLAlchemy 2.0 (mapped_column)
BD	SQLite en modo WAL
Migraciones	Alembic
Auth contraseñas	Argon2id (argon2-cffi)
Auth sesiones	JWT HS256 (python-jose)
Validacion	Pydantic v2

Contextos acotados implementados

identity	Usuarios (admin/editor), login JWT, guardas de rol
content	CRUD, versionado inmutable, papelera, articulos texto + ejercicios HTML
taxonomy	Ciclos, cursos y asignaturas configurables (catalogos)
configuration	Configuracion del sitio: paleta activa, paletas personalizadas

Regla de dependencia

infrastructure -> application -> domain. El dominio no importa FastAPI, SQLAlchemy ni Pydantic de request. Jamas. Comunicacion entre contextos solo via casos de uso o eventos de dominio.

Patron singleton de configuracion (corregido en V-0.8.0)

site_config es una unica fila con id fijo. El repositorio implementa get-or-create de forma idempotente: `_get_or_create_model()` consulta la fila y, si no existe, la crea y ejecuta `flush()` para registrarla en el identity map de SQLAlchemy. Asi, dentro del mismo caso de uso, `get()` y `save()` operan sobre la misma instancia y nunca se intenta un doble INSERT con la misma clave primaria.

3. Estructura de carpetas

```
backend/app/
  contexts/
    identity/{domain,application,infrastructure,api}/
    content/{domain,application,infrastructure,api}/
    taxonomy/{domain,application,infrastructure,api}/
    configuration/{domain,application,infrastructure,api}/
  shared/{domain,application,infrastructure}/
  bootstrap.py  main.py  config.py

frontend/src/
  app/{auth/,config/,App.tsx}
  pages/{CatalogoPage,ContenidoPage,LoginPage,...}
  pages/admin/{DashboardPage,ContenidosPage,TaxonomiaPage,
               UsuariosPage,ConfiguracionPage}
  shared/{api/{client.ts,schema.d.ts},ui/{PublicLayout,AdminLayout}}
  styles/tokens.css
```

4. Instalacion y despliegue

Requisitos (produccion con HTTPS)

- Docker 24+ y Docker Compose v2
- Dos dominios (APP_DOMAIN y SANDBOX_DOMAIN) con registros DNS A -> IP del servidor
- Puertos 80 y 443 redirigidos del router al servidor (para Let's Encrypt y HTTPS)

Arranque rapido con Docker (Caddy + HTTPS)

```
# 1. Descomprimir
unzip plataforma-educativa-v0.9.0.zip && cd plataforma-educativa-v0.9.0

# 2. Configurar variables de entorno (.env en la raiz)
cp .env.example .env
# Editar: APP_DOMAIN, SANDBOX_DOMAIN, ACME_EMAIL, SECRET_KEY, admin.
# APP_DOMAIN=plataforma.tudominio.com
# SANDBOX_DOMAIN=sandbox.tudominio.com
# ACME_EMAIL=tu-email@tudominio.com

# 3. DNS: registros A de ambos dominios -> IP publica del servidor.
# Router: redirigir 80 y 443 al servidor.

# 4. Levantar (construye las imagenes; Caddy pide los certificados)
docker compose up -d --build
```

Plataforma Educativa - Manual Tecnico y de Usuario V-0.10.1

```
docker compose logs -f caddy # ver la emision de certificados
```

```
# Web: https://APP_DOMAIN (el acceso es solo por dominio+HTTPS, no por IP:puerto)
```

```
# El entrypoint del api ejecuta: alembic upgrade head + crea admin si no hay usuarios
```

Variables de entorno (.env, en la raiz)

APP_DOMAIN	Dominio de la web (p. ej. plataforma.tudominio.com)
SANDBOX_DOMAIN	Subdominio del sandbox (p. ej. sandbox.tudominio.com)
ACME_EMAIL	Email para Let's Encrypt
SECRET_KEY	OBLIGATORIO cambiar en produccion (min 32 chars)
DEFAULT_ADMIN_EMAIL	admin@plataforma.local
DEFAULT_ADMIN_PASSWORD	CambiaMe1234 - CAMBIAR antes de desplegar
DATABASE_URL	sqlite:///./data/app.sqlite3
SANDBOX_BASE_URL / APP_ORIGINS / CORS	Derivan de los dominios en docker-compose

Arranque en desarrollo local

```
# Backend (Python 3.12+)
cd backend && python -m venv venv
source venv/bin/activate
pip install -r requirements.txt
cp .env.example .env
python -m alembic upgrade head
uvicorn app.main:app --reload --port 8001

# Frontend (Node.js 20+)
cd frontend && npm install
npm run dev # -> http://localhost:5173 (proxy /api -> :8001)
```

Crear primer admin manualmente

```
cd backend
python scripts/seed_admin.py admin@midominio.com MiPassword123
```

5. Referencia de la API REST

Base URL: <http://localhost:8001/api/v1> | Formato: JSON | Auth: Bearer JWT

Autenticacion

Metodo	Ruta	Auth	Descripcion
POST	/auth/token	-	Login. Form: username + password. Devuelve JWT.

Usuarios (/users/)

Metodo	Ruta	Auth	Descripcion
GET	/users/	admin	Listar todos los usuarios
POST	/users/	admin	Crear usuario (email, password, nombre, rol)

Contenidos (/contenidos/)

Metodo	Ruta	Auth	Descripcion
GET	/contenidos/	-	Listar contenidos publicados (catalogo publico)
GET	/contenidos/{id}	-	
POST	/contenidos/	editor+	Crear contenido (sanea body_html de texto)
PUT	/contenidos/{id}	editor+	Actualizar (re-sanea body_html de texto)
POST	/contenidos/{id}/html	editor+	Subir HTML de ejercicio (multipart)
DELETE	/contenidos/{id}/purgar	admin	Eliminar definitivamente (desde papelera)
POST	/media/imagenes	editor+	Subir imagen de articulo (multipart, raster)
POST	/contenidos/{id}/publicar	editor+	Publicar
DELETE	/contenidos/{id}	editor+	Mover a papelera (soft-delete)
POST	/contenidos/{id}/restaurar	editor+	Restaurar desde papelera
GET	/admin/contenidos/	admin	Listar todos (incluye papelera)

Taxonomia (/taxonomy/)

Metodo	Ruta	Auth	Descripcion
GET	/taxonomy/ciclos	-	Listar ciclos
POST	/taxonomy/ciclos	admin	Crear ciclo
PUT	/taxonomy/ciclos/{id}	admin	Actualizar ciclo
DELETE	/taxonomy/ciclos/{id}	admin	Eliminar ciclo
GET	/taxonomy/cursos	-	Listar cursos (filtrar: ?ciclo_id=...)
POST	/taxonomy/cursos	admin	Crear curso
PUT	/taxonomy/cursos/{id}	admin	Actualizar curso
DELETE	/taxonomy/cursos/{id}	admin	Eliminar curso
GET	/taxonomy/asignaturas	-	Listar asignaturas
POST	/taxonomy/asignaturas	admin	Crear asignatura (+ color opcional)
PUT	/taxonomy/asignaturas/{id}	admin	Actualizar asignatura
DELETE	/taxonomy/asignaturas/{id}	admin	Eliminar asignatura

Configuracion del sitio (/config/)

Metodo	Ruta	Auth	Descripcion
GET	/config/	-	Obtener config: nombre, fuente, fondo, paleta, paletas
PUT	/config/general	admin	Cambiar nombre del sitio y fuente de letra
PUT	/config/paleta	admin	Activar paleta (predefinida o personalizada)
POST	/config/paletas	admin	Crear paleta personalizada
PUT	/config/paletas/{id}	admin	Actualizar paleta personalizada
DELETE	/config/paletas/{id}	admin	Eliminar paleta personalizada

Mantenimiento (solo admin)

Metodo	Ruta	Auth	Descripcion
GET	/admin/backups	admin	Listar copias de seguridad existentes
POST	/admin/backups	admin	Crear una copia de seguridad ahora

Nota V-0.8.0: estos endpoints crean la fila singleton de configuracion de forma idempotente. La primera escritura sobre una BD sin configuracion previa ya NO produce 500.

Origen sandbox (servidor aparte: :8002 dev / sandbox.<dominio> prod)

Metodo	Ruta	Auth	Descripcion
GET	/ejercicio/{hash}	-	Sirve el HTML del ejercicio con CSP estricta
GET	/health	-	
			Readiness del servidor sandbox

Paletas predefinidas disponibles

cielo	Cielo Azul - tonos azules claros
bosque	Bosque Magico - tonos verdes naturales
coral	Coral Feliz - tonos rosas y rojos suaves
sol	Sol Brillante - tonos amarillos y naranjas
lavanda	Lavanda Sonadora - tonos morados suaves
estandar	Estandar - neutros, sin color fuerte

6. Modelo de datos**Tabla: user**

id	UUID (str) PK
email	VARCHAR(255) UNIQUE NOT NULL
nombre	VARCHAR(255)
hashed_password	VARCHAR(255) - Argon2id
rol	VARCHAR(50) - 'admin' 'editor'
activo	BOOLEAN
creado_en	DATETIME

Tabla: content

id	UUID (str) PK
titulo	VARCHAR(500)
tipo	VARCHAR(50) - 'interactivo' 'texto'
estado	VARCHAR(50) - borrador publicado archivado papelera
ciclo_id / curso_id / asignatura_id	UUID FK nullable
hash_html	VARCHAR(64) nullable - SHA-256 del HTML interactivo (servido en sandbox)
body_html	TEXT nullable - HTML sanitizado (tipo=texto)
creado_en / actualizado_en	DATETIME

Tabla: ciclo / curso / asignatura

id	UUID (str) PK
nombre	VARCHAR(255) UNIQUE (ciclo/asignatura)
orden	INTEGER
ciclo_id	UUID FK - solo en tabla curso
color	VARCHAR(7) nullable - solo en tabla asignatura

Tabla: site_config (singleton)

id	VARCHAR(36) PK fijo - '00000000-0000-0000-0000-000000000001'
nombre_sitio	VARCHAR(255) - nombre visible del sitio
paleta_activa	VARCHAR(100) - ID de la paleta activa
paletas_json	TEXT - JSON array con paletas personalizadas
fuentes_activa	VARCHAR(100) - ID de la fuente activa (default 'sistema')
fondo_activo	VARCHAR(100) - ID del fondo/estampado (default 'ninguno')

7. Seguridad

Autenticacion y autorizacion

- Contraseñas con Argon2id. Mínimo 8 caracteres.
- JWT HS256 firmado con SECRET_KEY. Expiración configurable.
- Roles: admin (completo) y editor (solo contenidos).
- Endpoints de lectura pública sin autenticación.

Aislamiento del sandbox (ejercicios interactivos)

- `iframe sandbox='allow-scripts'` (SIN `allow-same-origin`).
- Servidos desde un origen distinto (`sandbox.<dominio>` prod, :8002 dev) con CSP estricta.
- El JS del ejercicio no accede a cookies ni localStorage del origen principal.
- Nunca se renderiza HTML de ejercicio en el origen de la app.

Sanitización asimétrica

- HTML de artículos (tipo=texto): SIEMPRE sanitizado en servidor (Bleach).
- HTML de ejercicios (tipo=interactivo): NO sanitizado (debe ejecutar JS).
- HTML de ejercicios servido aislado: el sandbox y la CSP sustituyen a la sanitización.

Privacidad y protección de menores

- Sin cuentas de alumno, sin cookies de seguimiento, sin perfilado.
- Visitas anónimas y agregadas. Sin publicidad dirigida a menores (DSA art. 28).
- Datos mínimos: solo email y contraseña para usuarios con rol.

8. Tests

Unitarios (dominio + handlers)	mocks de repositorios, sin BD
Integración (endpoints)	SQLite en memoria, TestClient FastAPI
Regresión configuración	fixture con autoflush=False (igual a producción)

Mantenimiento	backup service (rotacion), purga papelera, endpoints admin
Total	123 tests - todos pasan en V-0.10.1

```
cd backend
pytest -v                # todos
pytest -v tests/unit/    # solo unitarios
pytest -v tests/integration/ # solo integracion
pytest --cov=app --cov-report=html # cobertura
```

PARTE II - MANUAL DE USUARIO

9. Acceso publico - Catalogo

La portada del sitio muestra el catalogo de contenidos publicados. No es necesario registrarse ni hacer login. Los visitantes pueden navegar por el catalogo, abrir ejercicios interactivos (en iframe aislado) y leer articulos de texto.

Tipos de contenido

Ejercicio interactivo	HTML/CSS/JS autocontenido en iframe sandbox servido desde un origen aislado. Sin acceso al origen de la app. Seguro para menores.
Articulo de texto	HTML enriquecido sanitizado. Imagenes, listas, tablas y formato de texto permitidos.

10. Login al panel de administracion

Pulsar 'Acceder' en la barra de navegacion publica. Introducir email y contrasena. Tras el login, el sistema redirige automaticamente al Panel Admin (/admin).

- El token JWT se almacena en localStorage con clave 'auth_token'.
- Expiracion por defecto: 60 minutos.
- Para cerrar sesion: boton 'Cerrar sesion' en el sidebar del panel admin.

11. Panel admin - Inicio (Dashboard)

Muestra tarjetas con estadisticas del sitio: contenidos publicados, total de usuarios y ciclos configurados. Punto de entrada al panel de gestion.

12. Panel admin - Contenidos

Lista todos los contenidos con su estado: borrador, publicado, archivado, papelera. Filtrado y paginacion disponibles en versiones futuras.

Acciones disponibles

Publicar	Pone el contenido en estado 'publicado' (visible en catalogo).
Borrar	Mueve a la papelera (borrado logico, recuperable).
Restaurar	Recupera un contenido de la papelera.

Crear: boton + Nuevo articulo. Se elige el tipo (texto o interactivo). En los interactivos, tras crear el contenido se sube el fichero HTML desde la edicion.

13. Panel admin - Taxonomia

Gestion de ciclos, cursos y asignaturas educativas del sistema espanol. Todos los catalogos son configurables; no hay valores fijos en el sistema.

Gestión de ciclos y cursos

- Anadir: escribir el nombre en el campo de texto y pulsar '+ Anadir'.
- Editar: pulsar el icono lapiz o hacer doble clic sobre el nombre. Confirmar con Enter o la marca de verificación. Cancelar con Escape.
- Eliminar: pulsar el icono papelera (solicita confirmación).

Gestión de asignaturas

Mismas acciones que ciclos y cursos, con la opción adicional de asignar un color representativo mediante un selector de color HTML.

14. Panel admin - Apariencia y ajustes

Ajustes generales: nombre del sitio

En la sección 'Ajustes generales', escribir el nombre deseado en el campo 'Nombre del sitio' (máximo 80 caracteres) y pulsar 'Guardar cambios'. El nombre aparece al instante en la barra pública, el pie de página y el sidebar de administración.

Ajustes generales: fuente de letra

Debajo del nombre se muestra una rejilla de fuentes, cada una previsualizada en su propia tipografía. Hacer clic en la deseada y pulsar 'Guardar cambios' para aplicarla a todo el sitio. Catálogo disponible:

Sistema	Fuente nativa del dispositivo. Rápida, sin descarga.
Nunito	Redondeada y cálida. Acogedora para los más pequeños.
Quicksand	Geométrica y suave, con aire moderno.
Lexend	Diseñada para mejorar la fluidez de lectura.
Atkinson Hyperlegible	Máxima legibilidad, pensada para baja visión.
Andika	Creada para quienes aprenden a leer.

Las fuentes (salvo Sistema) son self-hosted: las sirve la propia app, sin contactar con ningún servidor externo, protegiendo la privacidad de los menores.

Ajustes generales: fondo / estampado

Rejilla con Ninguno (fondo liso) y 6 temáticas: Aula, Naturaleza, Espacio, Oceano, Geométrico y Granja. Cada opción muestra una vista previa. Al elegir una y pulsar 'Guardar cambios', el estampado se aplica a todo el sitio.

Aula	Pizarra, lapiz, reloj, regla.
Naturaleza	Pino, hoja, seta, bellota.
Espacio	Cohete, planeta, estrella, luna.
Oceano	Pez, concha, burbujas, estrella de mar.
Geométrico	Formas y lunares (neutro).
Granja	Granero, trigo, valla, sol.

El estampado se recolora con la paleta activa y se muestra a baja opacidad, detrás del contenido, para no restar legibilidad. Los patrones son SVG self-hosted.

Activar una paleta predefinida

En la seccion 'Paletas predefinidas', hacer clic en cualquier swatch de color. La paleta se activa inmediatamente en todo el sitio (publico y privado). La paleta activa muestra un badge 'Activa' y borde destacado.

Como funciona la paleta

Cada paleta define cuatro colores base: Fondo (bg), Superficie (surface), Texto (fg) y Color principal (primary). El sistema deriva automaticamente colores secundarios (hover, muted, border) mediante calculo de opacidad y oscurecimiento. Los colores se aplican como variables CSS en :root.

Crear una paleta personalizada

- Pulsar el boton '+ Nueva paleta' en la seccion 'Paletas personalizadas'.
- Introducir un nombre descriptivo.
- Elegir los 4 colores con los selectores de color del navegador.
- Observar el preview en vivo (muestra como quedaria la superficie y el color principal).
- Pulsar 'Guardar'. La paleta queda disponible para activar.

Manejo de errores (mejora de V-0.8.0)

Si una operacion de paleta falla (por ejemplo, crear una paleta con un ID ya existente o eliminar la paleta actualmente activa), la pagina muestra un mensaje de error claro en la parte superior en lugar de no hacer nada. Antes, estos fallos se ignoraban en silencio.

Eliminar una paleta personalizada

Pulsar el boton 'x' en la esquina del swatch de la paleta personalizada. No es posible eliminar la paleta actualmente activa. Las paletas predefinidas no se pueden eliminar.

15. Panel admin - Usuarios (solo admin)

Accesible unicamente para el rol 'admin'. Lista todos los usuarios del sistema.

Crear un nuevo usuario

- Rellenar email, nombre, contrasena y rol (admin o editor).
- Pulsar 'Crear usuario'.
- La contrasena se almacena hasheada con Argon2id; nunca en texto plano.
- El email debe ser unico en el sistema.

16. Roadmap

Hecho (V-0.10.1)	Robustez: backups automaticos de la BD + purga programada de papelera.
Hecho (V-0.9.0)	Produccion: HTTPS con Caddy (Let's Encrypt) + sandbox en subdominio.
Siguiente	E2E Playwright (incl. test seguridad sandbox). Usuario no-root en el backend.
Mas adelante	Logotipo configurable. Buscador full-text (FTS5). Contador de visitas/auditoria.